LTW — Operação e Segurança dos Sistemas

Disciplina 2 — Sistemas Operacionais | Projeto em Infraestrutura Computacional | versão de 29/10/2026

Este documento define o que a equipe de TI faz para manter os sistemas atualizados, protegidos e rastreáveis, quem faz, com que frequência e como se prova que foi feito. Ele usa a base fechada na Parte 1 (103 funcionários, 61 endpoints, 2 servidores Dell R450 com Hyper-V, 2 NAS QNAP) e as decisões da Parte 2 (Windows 11 Pro nas estações, Windows Server 2022 e Ubuntu 24.04 LTS nos servidores, Microsoft 365 para 12 usuários, backup com Veeam Community Edition).

Responsáveis são papéis (a TI tem 3 profissionais): TI-Sistemas/Segurança, TI-Infraestrutura e TI-Suporte. 'Gestor' é o líder do setor e 'Diretor' a Diretoria. Datas e versões de software foram conferidas em 29/10/2026; itens que dependem de fornecedor ou de teste estão marcados como pendência no fim.

1. Visão geral

Tema	Regra em uma frase	Ferramenta
Atualização	Piloto de 7 dias antes de liberar; servidores sempre um host por vez; janela 03:00–04:00 para operação 24h.	Windows Update for Business (GPO), Failover Cluster, unattended-upgrades
Malware	Antivírus ativo e atualizado em 100% das estações e servidores; ameaça detectada vira chamado.	Microsoft Defender Antivírus, filtros do Exchange Online, Knox/Play Protect nos tablets
Firewall	Entrada bloqueada por padrão em estação e servidor; banco só aceita as VMs de aplicação; sem RDP na internet.	Windows Defender Firewall (GPO), ufw no Ubuntu, firewall MikroTik (Redes)
Criptografia	Disco de notebooks e desktops com BitLocker (chave no AD); NAS-B e cópia externa cifrados; TLS nas aplicações.	BitLocker, QNAP, Veeam, HBS 3/Backblaze B2
Logs	Eventos de segurança centralizados e guardados por 12 meses; revisão semanal.	Event Forwarding no SRV-INFRA, syslog, PRTG
Contas administrativas	Ninguém é administrador por padrão; contas adm-* separadas, com MFA e revisão mensal.	AD, Windows LAPS, MFA
Entrada/saída de pessoas	Conta criada só com pedido do gestor; desativada no dia da saída.	Chamado + checklist

2. Atualização de sistemas

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Windows 11 Pro (49 estações)	Aplicar atualizações de qualidade e segurança por Windows Update for Business: anel piloto (3 profissionais de TI + 2 estações técnicas) e, após 7 dias sem problema, anel geral. Reinício fora do horário de uso; nas estações 24h (PA, Segurança) a janela é 03:00–04:00 com plantonista avisado.	TI-Suporte	Mensal (segunda quarta-feira após o Patch Tuesday)	Relatório de conformidade da GPO/Windows Update; meta: 95% das estações com a última atualização de qualidade em até 21 dias	Relatório mensal salvo em \\SRV-PACS\Setores\TI
Versão do Windows 11	Manter 25H2 (Home/Pro com suporte até 12/10/2027). Planejar o salto para a versão seguinte a partir de 07/2027.	TI-Sistemas	Anual	Inventário de versões; nenhum PC fora de versão suportada	Planilha de inventário

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Windows Server 2022 (hosts e 5 VMs)	Atualizar nós do cluster um por vez: esvaziar o nó (migração ao vivo), aplicar, reiniciar, devolver; depois o outro nó. VMs críticas (SRV-DB, PRONT) em janela combinada com a plantonista do PA. Suporte principal do WS2022 já acabou em 14/10/2026; segurança até 15/10/2031.	TI-Infraestrutura	Mensal (7 dias após o Patch Tuesday)	Lista de KBs instalados por servidor; cluster saudável (Test-Cluster sem erro) ao final	Registro do chamado de mudança
Ubuntu Server 24.04 LTS (SRV-DB)	Atualizações de segurança automáticas (unattended-upgrades); reinício de kernel em janela. PostgreSQL só recebe versão menor.	TI-Sistemas	Semanal (segurança) / mensal (reinício)	apt list --upgradable vazio de segurança; uptime e versão do kernel	Log de atualização
BIOS/iDRAC dos Dell R450 e firmware QNAP	Atualizar firmware após ler as notas e ter backup recente; um equipamento por vez.	TI-Infraestrutura	Semestral	Versão no PRTG/console comparada ao catálogo do fabricante	Chamado de mudança com notas de versão
Tablets Samsung (12)	Atualizações de segurança e do sistema liberadas pelo MDM; aplicativos obrigatórios fixados.	TI-Suporte	Mensal	Painel do MDM: dispositivos desatualizados > 60 dias = 0	Captura do painel
Aplicações de fornecedor (ERP, prontuário, PACS, iDSecure)	Atualizar só com homologação do fornecedor, backup da VM antes e teste na VM clonada.	TI-Sistemas + Gestor	Conforme versão	Teste de aceite assinado pelo gestor do setor	Termo de aceite

3. Proteção contra malware

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Antivírus em estações e servidores	Microsoft Defender Antivírus ativo com atualização automática; proteção em tempo real e proteção contra adulteração ligadas por GPO. Exclusões necessárias para Hyper-V e PostgreSQL seguem a documentação do fornecedor e são registradas.	TI-Sistemas	Contínuo; revisão mensal	Relatório de status do Defender (GPO/PowerShell) sem estação desatualizada; PRTG alerta se o serviço parar	Relatório mensal
Regras de redução de superfície	Habilitar regras ASR essenciais (macros do Office que baixam executáveis, scripts ofuscados) primeiro em modo auditoria por 14 dias.	TI-Sistemas	Implantação + trimestral	Eventos de auditoria revisados antes de bloquear	Ata da revisão
E-mail e anexos	Filtros do Exchange Online (12 caixas). As demais 80 pessoas não têm e-mail corporativo na Parte 1: proibir anexos de origem desconhecida nos aplicativos e capacitar.	TI-Sistemas	Contínuo	Relatório de quarentena do Microsoft 365	Relatório mensal
Mídias removíveis	Bloquear armazenamento USB por GPO, exceto estações autorizadas (TI e Diagnóstico para exportar exames, com aprovação do gestor).	TI-Sistemas	Contínuo; exceções revisadas trimestralmente	Lista de exceções confere com GG de exceção	Lista de exceções
Tablets	Google Play Protect e Knox ativos; instalar apps só da lista aprovada no MDM.	TI-Suporte	Contínuo	Painel do MDM	Captura do painel

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Tratamento de ameaça detectada	Isolar a estação da rede, abrir chamado de segurança, varredura completa, trocar a senha do usuário e avaliar o impacto. Servidor afetado: isolar e restaurar de backup limpo.	TI-Sistemas	Sob demanda (resposta em até 1 h em horário comercial, 4 h fora dele)	Chamado fechado com causa e ação	Chamado

4. Firewall e segmentação

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Firewall nas estações	Windows Defender Firewall ligado em todos os perfis por GPO; entrada bloqueada exceto gerenciamento a partir das estações técnicas de TI.	TI-Sistemas	Contínuo; revisão trimestral	Relatório de GPO; teste de varredura interna por amostragem	Relatório trimestral
Firewall nos servidores	Windows Server: apenas as portas de cada serviço (ver catalogo-de-servicos.xlsx). Ubuntu: ufw permitindo 5432 somente dos IPs das VMs de aplicação e SSH somente das estações técnicas.	TI-Infraestrutura	Revisão trimestral	Exportar regras e comparar com o catálogo; varredura de portas a partir de uma estação comum	Exportação das regras
Firewall de perímetro e VPN	Regras definidas pela disciplina de Redes: nada exposto à internet exceto o necessário; acesso remoto só por VPN com MFA; RDP proibido na internet.	TI-Infraestrutura (Redes)	Revisão trimestral	Exportação da configuração do MikroTik comparada com a versão aprovada	Exportação da configuração
Segmentação	VLANs separadas para usuários, tablets, impressoras, câmeras/NVR, servidores e gerenciamento (iDRAC e NAS). Câmeras não alcançam servidores nem estações.	TI-Infraestrutura (Redes)	Revisão semestral	Teste de ping/porta entre VLANs conforme matriz de rede	Matriz de rede testada

5. Criptografia

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Disco das estações	BitLocker em todos os 9 notebooks e 40 desktops (TPM + PIN opcional nos notebooks da Diretoria); chave de recuperação gravada no AD.	TI-Sistemas	Na implantação; auditoria mensal	Relatório: 100% dos volumes de sistema 'Protegido' e chave no AD	Relatório mensal
Tablets	Criptografia nativa do Android Enterprise exigida pelo MDM, com bloqueio de tela e apagamento remoto.	TI-Suporte	Contínuo	MDM: dispositivos não conformes = 0	Captura do painel
Dados em trânsito	HTTPS/TLS nas aplicações web (certificado interno ou público); SMB com assinatura/criptografia nas pastas de RH e Financeiro; PostgreSQL com SSL.	TI-Sistemas	Revisão semestral; certificados 30 dias antes de vencer	Teste de conexão; alerta de validade no PRTG	Inventário de certificados
Backup e cópia externa	Backups do Veeam cifrados com senha; NAS-B com volume cifrado; cópia no Backblaze B2 cifrada antes do envio (HBS 3). Senhas em cofre físico/lacrado com custódia dividida.	TI-Sistemas	Contínuo; teste de restauração trimestral	Restaurar um arquivo cifrado em teste e confirmar que a chave está no cofre	Ata do teste

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Chaves e segredos	Chaves BitLocker no AD; senhas administrativas em cofre de senhas da TI (nunca em pasta de rede); senha de emergência lacrada.	TI-Sistemas	Revisão trimestral	Conferir lacre e acessos ao cofre	Registro de custódia

6. Logs e auditoria

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Logs de segurança do Windows	Encaminhar eventos de logon, bloqueio, criação/alteração de contas e grupos, limpeza de log e acesso às pastas auditadas (RH, Financeiro, Diretoria, Prontuário) para o SRV-INFRA.	TI-Sistemas	Contínuo; retenção de 12 meses (decisão da equipe; confirmar exigências legais/LGPD com o jurídico)	Evento de teste aparece no coletor; espaço de log monitorado	Exportação semanal para o NAS-B
Logs de equipamentos	Firewall, NAS, switches e iDRAC enviam syslog ao SRV-INFRA (coletor de syslog, por exemplo o sensor Syslog Receiver do PRTG).	TI-Infraestrutura	Contínuo	Mensagem de teste por equipamento a cada trimestre	Relatório de teste
Logs das aplicações	Prontuário, ERP, PACS e iDSecure: ativar o log de acesso do próprio sistema e guardar por 12 meses.	TI-Sistemas + fornecedor	Contínuo	Consulta de um acesso conhecido no log	Relatório trimestral
Revisão dos logs	Revisar tentativas de logon falhas, bloqueios, alterações em grupos privilegiados e uso das contas adm-*/break-glass.	TI-Sistemas	Semanal (rápida) e mensal (completa)	Ata com ocorrências e ações	Ata semanal
Relógio e fuso	Todos os servidores sincronizados com o domínio (PDC → NTP externo).	TI-Infraestrutura	Mensal	w32tm /monitor sem desvio > 2 min	Saída do comando

7. Contas administrativas e senhas

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Separação de contas	Cada profissional de TI tem conta comum e conta adm-<nome>. A adm-* nunca lê e-mail nem navega e só entra em estação técnica ou servidor.	TI-Sistemas	Contínuo	Lista de membros de GG-TI-ADMIN, Domain Admins e administradores locais confere com a lista aprovada	Relatório mensal
Domain Admins mínimo	No máximo 2 contas nominais + 1 conta de emergência (break-glass) lacrada; troca imediata da senha após uso.	Diretor + TI-Sistemas	Revisão mensal	Contagem de Domain Admins ≤ 3	Relatório mensal
Administrador local	Windows LAPS troca a senha do administrador local a cada 30 dias e a guarda no AD.	TI-Suporte	Automático	Amostra de 5 estações com senha LAPS válida	Relatório
Senhas dos usuários	Mínimo de 12 caracteres, sem repetir senhas recentes; bloqueio por 15 min após 10 falhas; troca obrigatória só em suspeita de vazamento; MFA no Microsoft 365, VPN e contas adm-*.	TI-Sistemas	Contínuo	Política do AD exportada e comparada com este documento	Exportação

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Contas inativas	Desativar contas sem logon há 60 dias (exceto afastamentos informados pelo RH) e excluir após 180 dias.	TI-Sistemas	Mensal	Relatório de contas inativas	Relatório
Revisão de acessos	Donos das pastas e aplicações confirmam os membros dos grupos; remover o que não for confirmado.	Gestor / Diretor	Trimestral (privilegiados: mensal)	Planilha de conferência assinada	Planilha assinada

8. Entrada, transferência e saída de funcionários

A LTW funciona 24h e tem rotatividade em Facilities, Pronto Atendimento e Internação; por isso a saída é tratada no mesmo dia.

Evento	Passos	Responsável	Prazo	Como verificar	Evidência
Entrada	1) RH abre o chamado com nome, setor, perfil e data; 2) Gestor aprova os recursos; 3) TI cria a conta, coloca no grupo GG- do setor, licencia Microsoft 365 se o perfil previr, entrega equipamento ou posto, registra o patrimônio; 4) Usuário recebe orientação e assina o termo de uso.	RH, Gestor, TI-Suporte	Conta pronta 1 dia útil antes do início	Login do primeiro dia funcionando; membros do grupo conferem com o pedido	Chamado + termo assinado
Transferência de setor	1) Gestor novo aprova; 2) TI remove o grupo antigo e coloca no novo no mesmo dia; 3) Dados pessoais migrados; pastas do setor antigo ficam com o gestor antigo.	Gestores, TI-Suporte	No dia da mudança	Usuário não pertence mais ao grupo antigo	Chamado
Saída	1) RH avisa no dia (ou antes, se programada); 2) TI desativa a conta e revoga sessões e tokens; 3) Retira licença Microsoft 365 e redireciona o e-mail ao gestor, se houver; 4) Recolhe notebook/tablet, limpa e reatribui; 5) Transfere pastas e arquivos ao gestor; 6) Revoga biometria/crachá no iDSecure e acessos de VPN.	RH, TI-Suporte, Segurança	No mesmo dia da saída	Conta desabilitada; sem sessão ativa; crachá inativo	Chamado + checklist
Exclusão definitiva	Após 30 dias da saída, arquivar o conteúdo (backup) e excluir caixa e perfil; após 180 dias excluir a conta.	TI-Sistemas	30 e 180 dias	Relatório de contas desativadas	Relatório
Conferência RH × AD	Cruzar a lista ativa do RH com as contas habilitadas; qualquer diferença vira chamado.	RH + TI-Sistemas	Mensal	Diferença = 0	Relatório assinado
Terceirizados e fornecedores	Conta nominal com data de término; acesso remoto só por VPN com MFA e acompanhado.	Gestor + TI	Revisão mensal	Nenhuma conta sem data de término	Lista

9. Monitoramento, incidentes e contingência 24h

Controle	O que fazer	Responsável	Frequência	Como verificar	Evidência guardada
Monitoramento	PRTG Free (até 100 sensores) para hosts, VMs, NAS, nobreak, switches, firewall, espaço em disco, RAID, jobs do Veeam e certificados. Alertas por e-mail ao grupo de TI e à plantonista.	TI-Infraestrutura	Contínuo; revisão semanal	Painel sem sensor em vermelho > 1 h; teste de alerta mensal	Captura do painel
Severidade e resposta	Crítica (PA, prontuário, banco, acesso fora): resposta imediata, 24h. Alta: até 4 h. Média: 1 dia útil. Baixa: 3 dias úteis.	TI plantão	Sob demanda	Tempo registrado em cada chamado	Relatório mensal de SLA
Contingência do PA/Internação	Procedimento em papel, impressão da ficha/prescrição e conta de contingência offline para consulta de prontuário. Ensaiar a recuperação com a plantonista.	TI + Responsável clínico	Ensaio semestral	Ata do ensaio com tempo e falhas	Ata
Restabelecimento após queda total	Seguir a ordem da aba 'Ordem de subida' do catalogo-de-servicos.xlsx (≈ 90 min estimados).	TI plantão	Ensaio anual	Cronometrar o ensaio	Ata
Capacidade	Acompanhar ocupação do NAS-A, NAS-B e RAM do nó sobrevivente (limite de 80%).	TI-Infraestrutura	Mensal	Relatório de capacidade	Relatório

10. Calendário operacional resumido

Frequência	Atividades
Diária	Conferir resultado dos backups (Veeam e dumps) e alertas do PRTG.
Semanal	Revisar logs de segurança; verificar pendências de atualização; teste de restauração de um arquivo aleatório.
Mensal	Patches (Windows 11 e Windows Server); relatórios de BitLocker, antivírus, LAPS, contas inativas e Domain Admins; conferência RH × AD; revisão dos grupos privilegiados; capacidade.
Trimestral	Teste de restauração de uma VM completa e do banco; revisão de acessos pelos donos; revisão do firewall; troca de senhas de serviço; teste do syslog.
Semestral	Firmware (BIOS/iDRAC/QNAP); ensaio de contingência do PA; revisão da segmentação.
Anual	Ensaio de queda total e restauração; revisão desta política e do plano de capacidade; avaliação de WS2025/Windows 11 versão seguinte.

11. Limites e pendências

- Retenção de logs de 12 meses é decisão da equipe; confirmar exigências legais e de LGPD com o jurídico antes do PDF final.
- Escolha do MDM dos tablets (Knox Suite × Microsoft Intune) ainda aberta (P-06).
- Ferramenta de chamados (ITSM) ainda não definida (P-03); até lá, registrar chamados em planilha compartilhada da TI.
- O Windows Update for Business pode ser trocado por WSUS se a rede não suportar o download simultâneo; decisão no piloto.
- Compatibilidade de impressoras e leitores com Windows 11 depende dos testes da aba Compatibilidade da matriz-de-sistemas.xlsx.
- PERFIL-CIRURGICO (11 pessoas) está fora do escopo; as regras acima passam a valer para ele quando houver equipamento e sistema definidos.